โครงการ

ระบบจัดการห้องสมุด (Library System)

ชื่อสมาชิก

นายปาลเดชา อ้นมงคล 66160027

นายกิตติศักดิ์ ภิญโญดม 66160114

นายธนกร เตียวตระกูล 66160128

นายนัชธ์ชาญยุทธ พัชรทับอุไร 66160133

โครงการนี้เป็นส่วนหนึ่งของการศึกษาหลักสูตรปริญญาวิทยาศาสตร์บัณฑิต

สาขาวิชาเทคโนโลยีสารสนเทศ คณะวิทยาการสารสนเทศ มหาวิทยาลัยบูรพา

ปีการศึกษา 2569

ลิขสิทธิ์ของคณะวิทยาการสารสนเทศ มหาวิทยาลัยบูรพา

1.Security Test Plan

1.บทนำ (Introduction)

1.1 วัตถุประสงค์ (Objectives)

เป้าหมายหลักของแผนการทดสอบนี้คือการสร้างแนวทางที่ชัดเจนในการตรวจสอบความปลอดภัยและคุณภาพของซอร์สโค้ดในระบบจัดการห้องสมุด เพื่อให้มั่นใจว่าระบบสามารถป้องกันการโจมตีทางไซเบอร์ที่สำคัญ และมีโครงสร้างโค้ดที่ง่ายต่อการบำรุงรักษาในอนาคต โดยเน้นไปที่

- การลดช่องโหว่ตามมาตรฐาน OWASP Top 10
- การรักษาระดับ Code Coverage ให้สูงกว่า 70%
- การตรวจพบและแก้ไขข้อบกพร่อง (Bugs) อย่างเป็นระบบ

1.2 ขอบเขตการทดสอบ (Scope)

การทดสอบจะครอบคลุมโมดูลหลักของระบบห้องสมุด ได้แก่

- ระบบลงชื่อเข้าใช้งาน (Authentication) และการจัดการเซสชัน
- ระบบค้นหาและยืม-คืนหนังสือ (Database Query)
- ระบบจัดการโปรไฟล์ผู้ใช้งานและการกรอกข้อมูล (Input Validation)
- คุณภาพของโค้ดในทุกไฟล์ (.js, .jsx, หรือภาษาที่เกี่ยวข้อง)

2. โครงสร้างทีมและบทบาทหน้าที่ (Team Roles)

ทีมงานประกอบด้วยสมาชิก 4 คน โดยแบ่งความรับผิดชอบตามความเชี่ยวชาญ ดังนี้

1. **Code Reviewer : นายธนกร**
   - รับผิดชอบการตั้งค่า ESLint/Prettier และทำ Static Analysis
   - ตรวจสอบโค้ดด้วยตนเอง (Manual Review) เพื่อหาข้อผิดพลาดทางตรรกะ
2. **Unit Test Engineer : นายกิตติศักดิ์**
   - ออกแบบและเขียนชุดทดสอบอัตโนมัติด้วย Jest
   - ติดตามและรายงานค่า Code Coverage ให้ได้ตามเป้าหมาย

3. **Security Tester : นายนัชธ์ชาญยุทธ**
    - ดำเนินการทดสอบเจาะระบบ (Manual Security Testing)
    - ทดสอบ SQL Injection, XSS และช่องโหว่ด้านความปลอดภัยอื่นๆ
4. **QA Analyst : นายปานเดชา**
    - วิเคราะห์และประเมินระดับความรุนแรงของช่องโหว่ (Vulnerability Assessment)
    - คำนวณค่า Metrics และสรุปรายงานความเสี่ยง

3. สภาพแวดล้อมและเครื่องมือที่ใช้ (Test Environment & Tools)

- **ภาษา/เฟรมเวิร์ก:** React / Node.js (ตามที่โปรเจกต์ใช้งาน)
- **Version Control:** GitHub สำหรับการ Commit งานและติดตาม Issues
- **Static Analysis:** ESLint (Security Plugin), Prettier
- **Testing Framework:** Jest และ React Testing Library
- **Security Testing Tools:** OWASP Payloads, Browser Developer Tools, Postman
- **Tracking:** GitHub Issues

4. กลยุทธ์การทดสอบ (Test Strategy)

4.1 Phase 1: Static Analysis & Unit Testing

- **Static Analysis:** รันเครื่องมือตรวจสอบอัตโนมัติเพื่อค้นหาช่องโหว่ระดับ Syntax และแนวทางปฏิบัติที่ไม่ปลอดภัย
- **Unit Testing:** ออกแบบชุดทดสอบ 30 เคส ครอบคลุมทั้งกรณีที่ข้อมูลถูกต้อง (Positive) และข้อมูลที่ผิดพลาด (Negative) เพื่อทดสอบ Error Handling

4.2 Phase 2: Security Testing (Focus Area)

มุ่งเน้นการทดสอบ 4 ด้านหลัก

1. **SQL Injection:** ทดสอบการป้อน Payload เพื่อเข้าถึงฐานข้อมูลโดยไม่ได้รับอนุญาต
2. **Cross-Site Scripting (XSS):** ทดสอบการฝัง Script ในช่องกรอกข้อมูลเพื่อขโมยข้อมูลคุกกี้หรือเซสชัน
3. **Authentication & Session:** ทดสอบความแข็งแกร่งของรหัสผ่าน และการรักษาความปลอดภัยของ Token/Session
4. **Input Validation:** ตรวจสอบการกรองข้อมูลประเภทไฟล์และตัวอักษรพิเศษ

5. เกณฑ์การยอมรับ (Acceptance Criteria)

ระบบจะถือว่าผ่านการทดสอบเมื่อเป็นไปตามเงื่อนไขดังนี้

- ไม่พบช่องโหว่ระดับ **Critical** หรือ **High** ที่ยังไม่ได้รับการแก้ไข
- **Code Coverage** โดยรวมต้องมีค่าไม่น้อยกว่า 70%
- มีผลการรัน **Unit Test** ที่ผ่านทั้งหมด (Passed 100%)
- มีการบันทึกและจัดการ **Bug Reports** ใน GitHub ครบถ้วนตามเป้าหมาย

6. เมตริกการวัดผล (Quality Metrics)

จะมีการคำนวณและรายงานค่าเมตริก 5 ตัว ได้แก่

1. **Defect Density:** จำนวนบัคที่พบต่อจำนวน Test Cases
2. **Test Coverage Percentage:** เปอร์เซ็นต์ความครอบคลุมของชุดทดสอบ
3. **Defect Removal Efficiency (DRE):** อัตราการแก้ไขบัคที่พบ
4. **Security Vulnerability Density:** สัดส่วนช่องโหว่ความปลอดภัยต่อบัคทั้งหมด
5. **Average CVSS Score:** คะแนนเฉลี่ยความรุนแรงของช่องโหว่ที่พบ

7. กำหนดการปฏิบัติงาน (Timeline)

- **สัปดาห์ที่ 1:** ติดตั้งเครื่องมือ, ทำ Static Analysis และเริ่มออกแบบ Unit Test Cases
- **สัปดาห์ที่ 2:** ดำเนินการเขียน Unit Test และเริ่มทดสอบ Security เบื้องต้น
- **สัปดาห์ที่ 3:** ทดสอบ Security อย่างละเอียด, สรุปผล Metrics และจัดทำรายงานฉบับสมบูรณ์

8. การบริหารความเสี่ยง (Risk Management)

ความเสี่ยง	ระดับความรุนแรง	แนวทางการแก้ไข
พบบัคจำนวนมากจนแก้ไขไม่ทัน	สูง	จัดลำดับความสำคัญ (Severity) และเลือกแก้บัคระดับ Critical ก่อน
เครื่องมือทดสอบมีความขัดแย้งกับโค้ดเดิม	กลาง	ตรวจสอบ Config ของ ESLint/Jest ให้ตรงกับเวอร์ชันของ Node.js
สมาชิกในทีมติดภารกิจอื่น	กลาง	ใช้ GitHub Issues ในการสื่อสารและส่งต่องานเพื่อให้งานดำเนินต่อไปได้

2.Code Review Checklist

หัวข้อการตรวจสอบ	ผลการตรวจสอบ	หมายเหตุ
1. Security & Safety		
ไม่มีการต่อสตริง SQL โดยตรง (หลีกเลี่ยง SQL Injection)	Pass	ใช้ Parameterized Queries (?) ทั้งหมด
มีการตรวจสอบสิทธิ์ (Authorization) ก่อนเข้าถึง API สำคัญ	Pass	ใช้ AuthMiddleware (JWT)
ไม่มีการ Hardcode Sensitive Data (เช่น Password/Secret Key)	Pass	แยกจัดการผ่าน Environment/Config
2. Logic & Functionality		
ฟังก์ชันทำงานถูกต้องตาม Business Logic (ยืม/คืน/จัดการสมาชิก)	Pass	ตรวจสอบผ่าน Unit Test แล้ว
มีการดักจับข้อผิดพลาด (Error Handling) เช่น Try-Catch	Pass	ครอบคลุมในส่วน Controller และ Query
3. Code Quality		
การตั้งชื่อตัวแปรและฟังก์ชันสื่อความหมาย (Naming Convention)	Pass	ใช้ CamelCase ตามมาตรฐาน JS
ไม่มีการประกาศตัวแปรทิ้งไว้โดยไม่ได้ใช้งาน (Unused Variables)	Pass	ตรวจสอบผ่าน ESLint/VS Code
โค้ดมีการแบ่งสัดส่วนชัดเจน (Separation of Concerns)	Pass	ใช้โครงสร้าง MVC

3. Static Analysis Report (ESLint)

RUN COMMAND :

-ติดตั้ง eslint

npm init @eslint/config

-รัน eslint

npx eslint src/

```
PS D:\Test_library_Test\Library-Management-v2> npx eslint src/
  5:25  error  'require' is not defined  no-undef
  9:1   error  'module' is not defined   no-undef

D:\Test_library_Test\Library-Management-v2\src\routes\members.js
  2:17  error  'require' is not defined  no-undef
  4:26  error  'require' is not defined  no-undef
  5:39  error  'require' is not defined  no-undef
  13:1  error  'module' is not defined   no-undef

✖ 155 problems (155 errors, 0 warnings)
```

-แก้ไขไฟล์ eslint

```
import globals from "globals";
import pluginJs from "@eslint/js";

/** @type {import('eslint').Linter.Config[]} */
export default [
  {
    files: ["**/*.js"],
    languageOptions: {
      sourceType: "commonjs", // บอก ESLint ว่าเราใช้ require/module.exports
      globals: {
        ...globals.node,     // เปิดใช้งานตัวแปรของ Node.js (require, process,
__dirname)
        ...globals.jest,     // เปิดใช้งานตัวแปรของ Jest (describe, test, expect)
      },
    },
  },
  pluginJs.configs.recommended,
```

```
];
```

-รัน eslint อีกรอบ

```
PS D:\Test_library_Test\Library-Management-v2> npx eslint src/
D:\Test_library_Test\Library-Management-v2\src\controllers\DashboardContr
ller.js
  2:9  error  'db' is assigned a value but never used  no-unused-vars

D:\Test_library_Test\Library-Management-v2\src\routes\borrowing.js
  5:22  error  'requireAdmin' is assigned a value but never used  no-unus
d-vars

✖5 problems (5 errors, 0 warnings)
```

-นำมาเขียนเป็นรายงานในไฟล์ bug-reports/bugs.md

```
| Bug ID | Title | File Location | Severity | Description |
| :--- | :--- | :--- | :--- | :--- |
| BUG-001 | **Security Risk:** Unused `requireAdmin` |
`src/routes/borrowing.js` |  Critical | Middleware ตรวจสอบสิทธิ์ Admin ถูกเรียกมาแต่ไม่ได้ใช้ใน
Route |
| BUG-002 | Unused `db` connection | `src/app.js` |  Low | ตัวแปรการเชื่อมต่อฐานข้อมูลไม่ได้ถูก
ใช้งานในไฟล์หลัก |
| BUG-003 | Unused `next` parameter | `src/app.js` |  Low | พารามิเตอร์ใน Middleware
Error Handler ไม่ถูกเรียกใช้ |
| BUG-004 | Unused `db` in Borrowing |
`src/controllers/BorrowingController.js` |  Low | มีการประกาศตัวแปร `db` ซ้ำซ้อนโดยไม่ได้ใช้งาน
|
| BUG-005 | Unused `db` in Dashboard |
`src/controllers/DashboardController.js` |  Low | ตัวแปร `db` ถูกจองหน่วยความจำไว้แต่ไม่ได้ใช้
งานจริง |
```

-แก้ไขบัคให้ครบทุกข้อ

-รัน eslint

```
● PS D:\Library_Project3\Library_Project3> npx eslint src/
○ PS D:\Library_Project3\Library_Project3>
```

= ไม่ขึ้น Error

4.Unit Tests

4.1 ภาพรวมการทดสอบ (Overview)

ระบบได้ใช้เครื่องมือ Jest ในการพัฒนาและรัน Unit Test โดยมีการเขียน Test Cases ครอบคลุมการทำงานของระบบหลักทั้งหมด (Models, Controllers, และ Middleware) เพื่อให้มั่นใจว่า Business Logic ของระบบห้องสมุดทำงานได้อย่างถูกต้องทั้งในกรณีใช้งานปกติ (Happy Path) และกรณีเกิดข้อผิดพลาด (Edge Cases)

4.2 ขอบเขตการทดสอบ (Test Suites Scope) การทดสอบถูกแบ่งออกเป็นโมดูลต่างๆ ดังนี้:

- Authentication & Middleware (Auth.test.js, AuthMiddleware.test.js): ทดสอบการเข้ารหัสผ่าน, การสร้าง JWT Token, และการป้องกัน API จากผู้ที่ไม่มีสิทธิ์
- Book Management (Book.test.js, BookModels.test.js): ทดสอบการเพิ่มหนังสือ, ค้นหา, การป้องกันการใส่ ISBN ซ้ำ, และเงื่อนไขห้ามลบหนังสือที่ถูกยืมอยู่
- Member Management (Member.test.js): ทดสอบระบบสมาชิก, การอัปเดตสถานะ, และขีดจำกัดการยืมหนังสือ
- Borrowing Process (Borrowing.test.js, DatabaseModels.test.js): ทดสอบกระบวนการยืม-คืนหนังสือ, การตรวจสอบสถานะค้างส่ง (Overdue), และการคำนวณจำนวนหนังสือที่ยืม

4.3 ตัวอย่างซอร์สโค้ดการทดสอบ (DatabaseModels.test.js)

```
const { initializeDatabase, db } = require('../database');
const Book = require('../models/Book');
const Member = require('../models/Member');
const Borrowing = require('../models/Borrowing');
const User = require('../models/User');
const { run } = require('../models/query');

describe('Final Models Coverage - 100% Push', () => {

  beforeAll(async () => {
    await initializeDatabase();
    // ล้างข้อมูลทุกตารางเพื่อป้องกัน ID ซ้ำ
    await run("DELETE FROM borrowing");
    await run("DELETE FROM members");
    await run("DELETE FROM books");
    // ลบ user ทดสอบเดิม (ถ้ามี)
    await run("DELETE FROM users WHERE username = 'testuser'");
  });

  afterAll((done) => {
    if (db) db.close(done);
    else done();
  });

  // --- Test ชุดที่ 1: เก็บกรณีใช้งานปกติ (Happy Path) ---
  test('Should achieve high coverage for All Models', async () => {
    // 1. ปั๊ม USER
    const userRes = await User.create('testuser', 'password123', 'Test User',
'librarian');
    const uId = userRes.lastID;
    await User.getAll();
    await User.findById(uId);
    await User.findByUsername('testuser');
    await User.update(uId, 'testuser_new', 'Updated Full Name', 'admin');
    await User.delete(uId);

    // 2. ปั๊ม MEMBER (ใช้ตัวเล็ก 'student' ตาม Constraint)
    const mRes = await Member.create('M-101', 'John Doe', 'john@test.com',
'081', 'student', 5);
    const mId = mRes.lastID;
    await Member.getAll();
    await Member.getActive();
    await Member.findById(mId);
    await Member.updateStatus(mId, 'active');
    await Member.getBorrowingCount(mId);
```

```
    // 3. ปั๊ม BOOK
    const bRes = await Book.create('B-101', 'Node.js Guide', 'Author', 'Pub',
2026, 'Edu', 10, 'A1');
    const bId = bRes.lastID;
    await Book.getAll();
    await Book.search('Node');
    await Book.getCategories();
    await Book.updateAvailableCopies(bId, 9);

    // 4. ปั๊ม BORROWING
    const brRes = await Borrowing.create(mId, bId, '2026-04-01', '2026-04-
08');
    const brId = brRes.lastID;
    await Borrowing.getAll();
    await Borrowing.getBorrowed();
    await Borrowing.getOverdue();
    await Borrowing.checkIfBookBorrowed(bId);
    await Borrowing.returnBook(brId, '2026-04-05', 0);

    expect(brId).toBeDefined();
  });

  // --- Test ชุดที่ 2: เก็บกรณีกิ่งก้าน (Edge Cases / Branches) เพื่อให้คะแนนพุ่ง ---
  test('Edge Cases for 100% Branches Coverage', async () => {
    // กรณีหาข้อมูลไม่เจอ (ใช้ .toBeFalsy() เพื่อกัน Error)
    const mem1 = await Member.findById(999999);
    const mem2 = await Member.findByCode('NO-WAY-001');
    const zeroCount = await Member.getBorrowingCount(999999);

    expect(mem1).toBeFalsy();
    expect(mem2).toBeFalsy();
    expect(zeroCount).toBe(0);

    const borr1 = await Borrowing.findById(999999);
    const isNotBorrowed = await Borrowing.checkIfBookBorrowed(999999);

    expect(borr1).toBeFalsy();
    expect(isNotBorrowed).toBe(false);

    const noIsbn = await Book.findByIsbn('NONE-123');
    expect(noIsbn).toBeFalsy();
  });

  test('Borrowing Deep Branches Coverage', async () => {
    // เตรียมข้อมูล
    const b = await Book.create('B-BR-1', 'Test', 'A', 'P', 2026, 'C', 1,
'L');
```

```
    const m = await Member.create('M-BR-1', 'User', 'e@m.com', '08',
'student', 3);
    const bId = b.lastID;
    const mId = m.lastID;

    // --- 1. ทดสอบกรณี NO RESULT (Branch: false) ---
    // เช็คหนังสือที่ยังไม่มีในประวัติการยืมเลย
    const isBorrNone = await Borrowing.checkIfBookBorrowed(9999);
    expect(isBorrNone).toBe(false);

    // --- 2. ทดสอบสถานะ 'borrowed' (Branch: OR - first part) ---
    const br1 = await Borrowing.create(mId, bId, '2026-04-01', '2026-04-08');
    const isBorr1 = await Borrowing.checkIfBookBorrowed(bId);
    expect(isBorr1).toBe(true);

    // --- 3. ทดสอบสถานะ 'overdue' (Branch: OR - second part) ---
    // ต้องอัปเดตเป็น overdue เพื่อให้ SQL ฝั่ง OR status = 'overdue' ทำงาน
    await Borrowing.updateStatus(br1.lastID, 'overdue');
    const isBorr2 = await Borrowing.checkIfBookBorrowed(bId); // ตัวนี้จะไปโดนเงื่อนไข
OR อันที่สอง
    expect(isBorr2).toBe(true);

    // เรียกใช้ฟังก์ชันที่กรองเฉพาะ overdue
    await Borrowing.getOverdue();

    // --- 4. ทดสอบกรณี COUNT = 0 (แต่มี result คืนมา) ---
    // คืนหนังสือแล้วเช็คอีกรอบ
    await Borrowing.returnBook(br1.lastID, '2026-04-05', 0);
    const isBorr3 = await Borrowing.checkIfBookBorrowed(bId);
    expect(isBorr3).toBe(false); // result.count จะเป็น 0
  });
  test('Member Branches Deep Dive', async () => {
    // 1. เตรียม Member และ Book/Borrowing เพื่อปั๊มเงื่อนไข OR
    const mRes = await Member.create('M-BR-X', 'Branch Test', 'b@test.com',
'08', 'student', 3);
    const mId = mRes.lastID;
    const bRes = await Book.create('B-BR-X', 'Title', 'A', 'P', 2026, 'C', 1,
'L');
    const bId = bRes.lastID;

    // --- Branch A: result เป็น Null (กรณีไม่มี record ใน borrowing เลย) ---
    // (เราเทสต์ไปใน Edge Case แล้ว แต่ทำซ้ำตรงนี้เพื่อความชัวร์)
    const countNone = await Member.getBorrowingCount(999999);
    expect(countNone).toBe(0);

    // --- Branch B: status = 'borrowed' (เงื่อนไข OR ตัวแรก) ---
    const br1 = await Borrowing.create(mId, bId, '2026-04-01', '2026-04-08');
    const count1 = await Member.getBorrowingCount(mId);
```

```
    expect(count1).toBe(1);

    // --- Branch C: status = 'overdue' (เงื่อนไข OR ตัวที่สอง) ---
    await Borrowing.updateStatus(br1.lastID, 'overdue');
    const count2 = await Member.getBorrowingCount(mId);
    expect(count2).toBe(1); // วิ่งผ่านเงื่อนไข overdue

    // --- Branch D: result มีค่าแต่ count เป็น 0 (กรณีคืนของแล้ว) ---
    await Borrowing.returnBook(br1.lastID, '2026-04-05', 0);
    const count3 = await Member.getBorrowingCount(mId);
    expect(count3).toBe(0);

    // เก็บตกฟังก์ชันที่เหลือเพื่อให้ Functions % พุ่ง
    await Member.getActive();
  });
});
```

3. Code Coverage Report

npm test -- --coverage

All files

87.36% Statements 325/372 **78.78%** Branches 130/165 **87.67%** Functions 64/73 **88.01%** Lines 323/367

Press *n* or *j* to go to the next uncovered block, *b*, *p* or *k* for the previous block.

Filter:

File	Statements		Branches		Functions		Lines	
controllers	84.77%	206/243	80.14%	109/136	96.15%	25/26	85.12%	206/242
middleware	100%	11/11	100%	12/12	100%	2/2	100%	11/11
models	85.71%	60/70	52.94%	9/17	82.22%	37/45	87.87%	58/66
routes	100%	48/48	100%	0/0	100%	0/0	100%	48/48

All files controllers

84.77% Statements 206/243 **80.14%** Branches 109/136 **96.15%** Functions 25/26 **85.12%** Lines 206/242

Press *n* or *j* to go to the next uncovered block, *b*, *p* or *k* for the previous block.

Filter:

File	Statements		Branches		Functions		Lines	
AuthController.js	86.95%	20/23	83.33%	10/12	100%	4/4	86.95%	20/23
BookController.js	91.22%	52/57	95.45%	42/44	100%	6/6	91.22%	52/57
BorrowingController.js	77.17%	71/92	61.11%	22/36	90%	9/10	78.02%	71/91
DashboardController.js	95%	19/20	50%	6/12	100%	1/1	95%	19/20
MemberController.js	86.27%	44/51	90.62%	29/32	100%	5/5	86.27%	44/51

All files middleware

100% Statements 11/11 **100%** Branches 12/12 **100%** Functions 2/2 **100%** Lines 11/11

Press *n* or *j* to go to the next uncovered block, *b*, *p* or *k* for the previous block.

Filter:

File	Statements		Branches		Functions		Lines	
auth.js	100%	11/11	100%	12/12	100%	2/2	100%	11/11

All files models

85.71% Statements 60/70 **52.94%** Branches 9/17 **82.22%** Functions 37/45 **87.87%** Lines 58/66

Press *n* or *j* to go to the next uncovered block, *b*, *p* or *k* for the previous block.

Filter:

File		Statements		Branches		Functions		Lines	
Book.js		75%	12/16	100%	0/0	63.63%	7/11	73.33%	11/15
Borrowing.js		85.71%	12/14	33.33%	1/3	80%	8/10	85.71%	12/14
Member.js		85.71%	12/14	33.33%	1/3	77.77%	7/9	85.71%	12/14
User.js		100%	9/9	100%	0/0	100%	6/6	100%	9/9
query.js		88.23%	15/17	63.63%	7/11	100%	9/9	100%	14/14

All files routes

100% Statements 48/48 **100%** Branches 0/0 **100%** Functions 0/0 **100%** Lines 48/48

Press *n* or *j* to go to the next uncovered block, *b*, *p* or *k* for the previous block.

Filter:

File		Statements		Branches		Functions		Lines	
auth.js		100%	8/8	100%	0/0	100%	0/0	100%	8/8
books.js		100%	11/11	100%	0/0	100%	0/0	100%	11/11
borrowing.js		100%	13/13	100%	0/0	100%	0/0	100%	13/13
dashboard.js		100%	6/6	100%	0/0	100%	0/0	100%	6/6
members.js		100%	10/10	100%	0/0	100%	0/0	100%	10/10

-<u>Vulnerability Assessment Report (CVSS Scoring)</u>

รหัส	ประเภทช่องโหว่	คำอธิบายและสาเหตุความเสี่ยง	คะแนน CVSS 3.1	สถานะและการแก้ไข
VA-01	SQL Injection	การรับค่า Input จากผู้ใช้ไปต่อกับคำสั่ง SQL โดยตรง ทำให้ผู้โจมตีสามารถดัดแปลง Query เพื่อดูข้อมูลหรือทำลายฐานข้อมูลได้	8.5	[แก้ไขแล้ว] ใช้ Parameterized Queries (?) ในไฟล์ query.js สำหรับทุกคำสั่ง SQL เพื่อแยก Data ออกจาก Command
VA-02	Broken Authentication	การไม่มีระบบตรวจสอบสิทธิ์ที่รัดกุม ทำให้ผู้โจมตีอาจสวมรอยเป็นผู้ดูแลระบบ (Admin) เพื่อเข้าถึงข้อมูลสำคัญ	7.5	[แก้ไขแล้ว] ใช้ JWT (JSON Web Token) และบังคับใช้ AuthMiddleware ใน API Endpoints ที่สำคัญทั้งหมด
VA-03	Sensitive Data Exposure	การเก็บข้อมูลความลับ เช่น Secret Keys หรือรหัสผ่าน ไว้ใน Source Code (Hardcoding) ซึ่งอาจหลุดรอดไปบน GitHub ได้	5.5	[แก้ไขแล้ว] ย้ายข้อมูลที่เป็นความลับไปไว้ในไฟล์ .env (Environment Variables) และตั้งค่า .gitignore ไม่ให้อัปโหลดไฟล์นี้
VA-04	Insufficient Input Validation	การไม่ตรวจสอบความถูกต้องของข้อมูลก่อนบันทึก เช่น การเว้นว่างฟิลด์สำคัญ หรือส่ง ISBN ซ้ำ ทำให้	5.3	[แก้ไขแล้ว] เพิ่ม Logic การตรวจสอบค่าว่างและความถูกต้อง (Validation) ในระดับ Controller ก่อนส่งเข้า Database

		ฐานข้อมูลเกิดข้อผิดพลาด		
VA-05	Cross-Site Request Forgery (CSRF)	ผู้โจมตีหลอกให้ผู้ใช้ที่ล็อกอินอยู่ ส่งคำขอ (Request) ที่ไม่พึงประสงค์เข้ามาในระบบผ่าน Session Cookie	3.0	[แก้ไขแล้ว] ระบบเปลี่ยนจากการใช้ Session Cookie แบบดั้งเดิม มาใช้ JWT แบบ Stateless ทำให้ลดความเสี่ยงจากการโจมตีประเภท CSRF